

Static Analysis

Establish Settings Procedure

Revision

Version 5
4/27/26 6:55 PM

SME

Charles Wilson

Abstract

This document describes the procedure used to perform the establish settings activity described in the **AVCDL** ^[1] secondary document **Static Analysis Report** ^[2].

Group / Owner

Security / Security Architect

Motivation

This document is motivated by the need to have early cybersecurity-related implementation feedback in the development of software for use within safety-critical, cyber-physical systems.

Note: Within the context of this document, the terms ***security*** and ***cybersecurity*** are used interchangeably. It is presumed that the term ***security*** is being used in reference to ***cybersecurity*** and not ***physical security***.

License

This work was created by **Torc Robotics** and is licensed under the **Creative Commons Attribution-Share Alike (CC BY-SA-4.0)** License.

<https://creativecommons.org/licenses/by/4.0/legalcode>

Audience

The audience of this document is the cybersecurity practitioner who will be conducting cybersecurity-specific static analysis.

Completeness of Output

Since static analysis is an as-is analysis, it is critical to ensure that the information gathered is as accurate and complete as possible. As with any cybersecurity assessment, it is not the place of the cybersecurity SME to make assumptions on the part of engineering. All information should be sourced from and confirmed by the owner of the element under consideration.

When information is not available for either a given section of the template or parts thereof, this should be noted. Major omissions should be recorded in the cybersecurity risk register.

Disposition of Output

Once completed, the generated output should be managed in the organization's document management system (DMS) as a document of record.

Entry Criteria

This document assumes that the reader understands the purpose of cybersecurity-relevant static analysis. Further, that the reader has read and understood the AVCDL **Static Analysis Report** ^[2] and **Secure Settings Document** ^[3] secondary documents.

Prerequisites – Development SME

Qualifications

It is required that the development SME is both a qualified and trained development SME with expertise in the element under consideration in the context of the tool under whose cybersecurity settings are being reviewed.

Note: The specific qualifications and training of development SMEs necessary to assert expertise in providing accurate information regarding the element under consideration is outside the scope of this document.

Note: The development group is responsible for determining and making available the appropriate SME for the analysis of the element under consideration.

Knowledge

It is required that the development SME have expertise in the element under consideration in the context of the tool under whose cybersecurity settings are being reviewed.

Prerequisites – Security SME

Qualifications

It is required that the security SME is both a qualified and trained security architect (shown above on title page as **Owner**) as defined by the **NIST NCWF** role SP-ARC-002 and detailed in the **NCWF Roles - Security Architect** section of the **AVCDL Background Material** elaboration document ^[10].

Knowledge

It is required that the cybersecurity SME understands the purpose of cybersecurity-relevant tool settings.

Background Information

It is required that the cybersecurity SME has read and understands the AVCDL **Static Analysis Report**, and **Secure Settings Document** secondary documents. Additionally, that the cybersecurity SME has taken training relevant to this activity.

Prerequisites – DevOps SME

Qualifications

It is required that the DevOps SME is both a qualified and trained DevOps SME with expertise in the build system used for the element under consideration in the context of the tool whose cybersecurity settings are being modified.

Note: The specific qualifications and training of DevOps SMEs necessary to assert expertise in providing accurate information regarding the build system used for the element under consideration is outside the scope of this document.

Note: The DevOps group is responsible for determining and making available the appropriate SME for the modifications to build system needed for the tool under consideration.

Knowledge

It is required that the DevOps SME have expertise in the build system used for the element under consideration in the context of the tool under whose cybersecurity settings need modification.

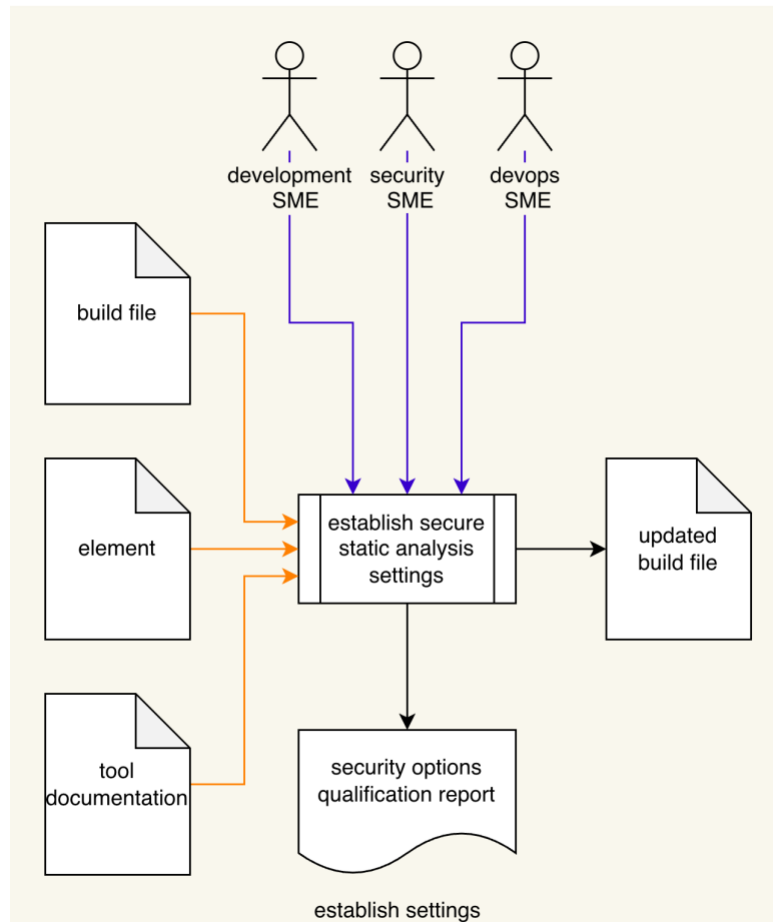
Prerequisites – Input Materials

It is required that the cybersecurity SME acquire all relevant documentation related to the tool under consideration necessary to complete the procedure.

It is required that the development group provide all relevant documentation related to the element under consideration necessary to complete the procedure.

Establish Settings Activity

The workflow diagram for the **establish settings** activity of the **Static Analysis Report** is shown below.

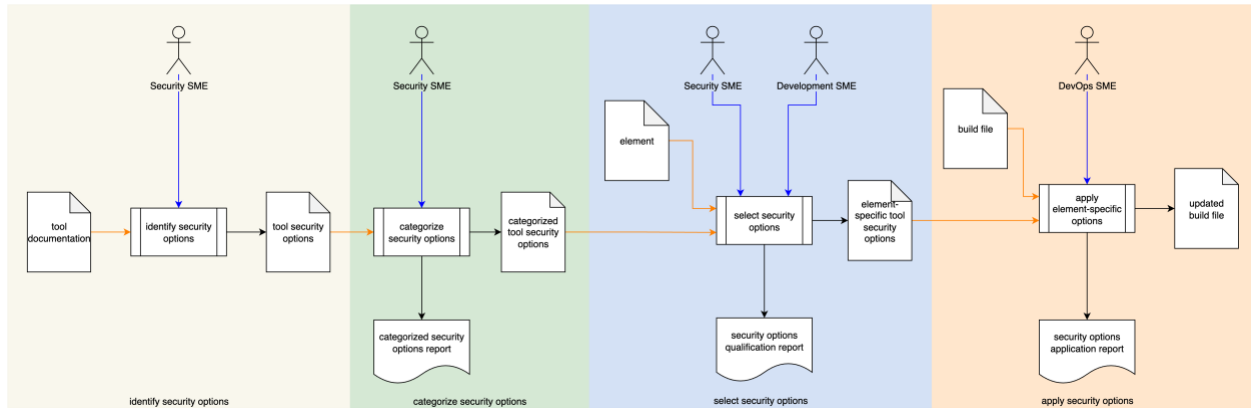


Using the **Element** under consideration, static analysis **Tool Documentation**, and **Build File**; the Development SME, Security SME, and DevOps SME will work together following the **Secure Settings Document** ^[2] process to determine what element aspects need to be considered and whether the element will require any annotation to restrict the scope of the analysis. An **Updated Build File** will be produced. A **Security Options Qualifications Report** is generated.

Note: The scope of the element may be as small as a single file, or as large as the entire project.

Settings Process Expanded

Consider the following diagram from the AVCDL **Secure Settings Document** secondary document.



Here we can see that the static analysis establish settings activity is more accurately described as a full process in and of itself. It is expressed as a single activity because its steps are common to multiple activities within the **AVCDL**.

Methodology

The methodology to use in this activity is to follow the procedures laid out in the **Secure Settings** procedures [\[4, 5, 6, 7\]](#).

Considerations

The following covers specific considerations regarding applying the secure settings process to static analysis. These will be addressed on an activity-by-activity basis.

Identify Options

Cybersecurity Relevant

Options should be chosen exclusively for their cybersecurity relevance. It is presumed that non-cybersecurity static analysis will make use of options appropriate to their specific use cases.

Released

Because of the nature of unreleased options, they should not be recommended for use. The goal is to provide high-quality, low false-positive issues.

Categorize Options

Practical

As noted in the **Secure Settings – Categorize Options Procedure**, categories should be both comprehensible and easy to adopt. It is recommended that a **must-do** / **may-do** approach be used.

Consistent Categorization

It is important to apply option categorization consistently and without bias. A consistent approach to categorization will lead to positive cybersecurity outcomes.

Select Options

Maturity

When selecting identified options for application, the maturity of the element under consideration and the use static analysis process in general should be considered.

Impact

Prioritize high cybersecurity impact options. More can be added later.

Apply Options

Option Interaction

Options are not always isolated from each other. This is especially true when dealing with compiler options. Verify that the selected options do not conflict with each other, and that they only operate within the desired scope.

Execution Impact

Static analysis is a resource intensive activity. Ensure that sufficient resources (time, memory, storage) are available.

Note: It is recommended that when using non-static analysis tools for cybersecurity-specific static analysis within the build system that they be run separately with only cybersecurity-relevant settings in order to minimize the work required to perform the triage.

Static Analysis Settings Templates

The static analysis settings may be documented using the **AVCDL tool cybersecurity options template** and **AVCDL element-specific tool cybersecurity options template** Microsoft Excel workbooks [\[8, 9\]](#).

Note: These workbooks are covered in the **AVCDL Secure Settings** tertiary documents [\[4, 5, 6\]](#).

Exit Criteria

This procedure is considered complete once the generated output has been entered into the organization's DMS as a document of record.

Note: The processes and procedures for entering documents into the DMS, or the updating thereof, are outside the scope of this document.

References

1. **AVCDL** (AVCDL primary document)
2. **Static Analysis Report** (AVCDL secondary document)
3. **Secure Settings Document** (AVCDL secondary document)
4. **Secure Settings – Identify Options Procedure** (AVCDL tertiary document)
5. **Secure Settings – Categorize Options Procedure** (AVCDL tertiary document)
6. **Secure Settings – Select Options Procedure** (AVCDL tertiary document)
7. **Secure Settings – Apply Options Procedure** (AVCDL tertiary document)
8. **AVCDL tool cybersecurity options template** (AVCDL template)
9. **AVCDL element-specific tool cybersecurity options template** (AVCDL template)
10. **AVCDL Background Material** (AVCDL elaboration document)